

WEEK 1 PROJECT DELIVERABLE

Enterprise Risk Assessment and Risk Register Development

PaySphere – Simulated Fintech GRC Case Study

Project Overview

This project involved conducting a simulated enterprise risk assessment for **PaySphere**, a Series B fintech organisation operating a cloud-hosted payment platform.

The objective of the project was to identify, analyse, prioritise and document key risks affecting the organisation and develop a structured risk register that could support ongoing governance, risk management and decision-making.

The assessment resulted in the development of an **eight-risk enterprise risk register** covering key areas including:

- Privileged access management
- Third-party and vendor concentration
- Regulatory compliance
- External data breaches
- Physical device security
- Business continuity and disaster recovery
- Web application security
- Information security assurance and ISMS credibility

The project applied a structured risk management methodology involving the identification of assets, threats and vulnerabilities, followed by inherent risk assessment, risk prioritisation, treatment planning, ownership assignment and ongoing monitoring considerations.

1. Business Scenario: PaySphere

PaySphere is a simulated Series B fintech startup processing approximately **₹500 crore in monthly transactions** and serving approximately **2 million active customers**.

The organisation operates with approximately **120 employees**, including a small IT team of eight personnel and no dedicated security team. Its infrastructure is hosted on **AWS in the Mumbai region**.

Information Processed and Stored

PaySphere processes and stores sensitive information including:

- Customer KYC documentation, including Aadhaar, PAN and address proof
- Tokenized card data
- Customer transaction histories
- Bank account information
- Mobile numbers and email addresses

Technology Environment

The organisation's technology environment includes:

- Mobile applications for iOS and Android
- A merchant web portal
- AWS cloud infrastructure
- Razorpay as the payment processor
- Twilio for OTP delivery
- Salesforce for customer support and CRM
- Slack for internal communication

Regulatory and Assurance Environment

The organisation operates within a regulatory and assurance environment involving:

- RBI Payment Aggregator Guidelines
 - PCI-DSS considerations for card data handling
 - India Digital Personal Data Protection requirements
 - Planned ISO 27001 certification
-

2. Key Risk Context

The risk assessment identified several known weaknesses within PaySphere's operating environment.

These included:

- No formal security awareness training programme
- Access reviews not completed for eight months
- Three developers retaining production database access for convenience
- No documented incident response plan
- Significant operational dependency on AWS, Razorpay and Twilio
- No formal vendor risk assessment process
- Unconfirmed security controls around the merchant web portal
- No current ISO 27001 certification despite plans to pursue certification

These weaknesses formed the basis for analysing how risks could materialise across PaySphere's technology, people, processes, third-party relationships and business operations.

3. Project Objective

The primary objective of this project was to develop a practical enterprise risk register by translating organisational weaknesses and business context into structured risk statements.

For each identified risk, the assessment considered:

1. The asset affected
2. The threat that could cause harm
3. The vulnerability or control weakness enabling the threat
4. The likelihood of occurrence
5. The potential impact
6. The inherent risk exposure
7. Risk velocity
8. Risk interdependencies
9. Key Risk Indicators
10. Recommended treatment
11. Risk ownership
12. Review frequency

The purpose was not only to identify risks, but to demonstrate how risks can be prioritised and translated into actionable governance and remediation activities.

4. Risk Assessment Methodology

The project followed a structured risk assessment approach.

Step 1: Understand Organisational Context

The assessment began by reviewing PaySphere's:

- Business model
- Technology environment
- Information assets
- Third-party dependencies
- Regulatory environment
- Known control weaknesses

Understanding organisational context was necessary to ensure that risks were grounded in realistic business conditions rather than being generic cybersecurity risks.

Step 2: Identify the Specific Risk

Each risk was defined as a specific scenario that could negatively affect the organisation.

The objective was to avoid overly broad statements and instead identify clear risk events connected to the organisation's assets and vulnerabilities.

Step 3: Identify the Affected Asset

The assessment identified the business, information, technology or relationship that could be negatively affected if the risk materialised.

Examples included:

- Production databases
 - Customer information
 - Payment operations
 - Enterprise client relationships
 - Critical technology services
 - Business continuity capabilities
-

Step 4: Identify the Threat

The threat represents the actor, event or circumstance capable of causing harm.

Examples included:

- External attackers
 - Privileged users
 - Vendor outages
 - Device theft
 - Application exploitation
 - Enterprise clients rejecting a vendor relationship
-

Step 5: Identify the Vulnerability

The vulnerability represents the weakness or control gap that could enable the threat.

Examples identified during the project included:

- Excessive privileged access
 - Lack of periodic access reviews
 - Vendor concentration
 - Absence of formal continuity planning
 - Unconfirmed web application security controls
 - Lack of independent ISMS validation
-

Step 6: Assess Inherent Risk

Each risk was assessed based on its inherent exposure.

The assessment considered:

- **Likelihood:** How likely the risk was to materialise
 - **Impact:** The potential business, regulatory, financial, operational or reputational consequences
-

Step 7: Analyse Risk Velocity

Risk velocity was included to assess how quickly the organisation could experience impact after the risk begins to materialise.

For example:

- A web application exploit can cause impact within minutes.
 - A loss of enterprise credibility may materialise gradually over multiple sales cycles.
-

Step 8: Identify Risk Interdependencies

Risks were not treated as completely isolated events.

The assessment identified situations where one risk could:

- Trigger another risk
- Increase the likelihood of another risk
- Amplify the impact of another risk

This approach provided a more realistic view of enterprise risk exposure.

Step 9: Define Key Risk Indicators

KRIs were identified to provide measurable signals that could indicate increasing risk exposure.

These indicators can support continuous risk monitoring and early identification of deteriorating conditions.

Step 10: Recommend Risk Treatment

The assessment concluded by identifying treatment strategies and priority remediation actions.

The primary treatment approach across the identified risks was **risk mitigation**.

5. Risk Scoring Approach

The assessment used a five-point scale for likelihood and impact.

Inherent Risk Formula

Inherent Risk Score = Likelihood × Impact

The score was used to prioritise risks according to their relative exposure.

The final register classified the identified risks primarily as:

- **HIGH**
- **CRITICAL**

The prioritisation reflects the nature of PaySphere's operating environment, including its handling of sensitive financial and personal information and its dependence on critical technology and third-party services.

6. Executive Risk Register Summary

Risk ID	Risk Title	Inherent Risk Rating
PSR-001	Excessive Privileged Production Access	CRITICAL
PSR-002	Critical Vendor Concentration Risk	CRITICAL
PSR-A	Regulatory Non-Compliance	CRITICAL

Risk ID	Risk Title	Inherent Risk Rating
PSR-B	External Data Breach Risk	CRITICAL
PSR-005	Physical Loss of Employee Devices	HIGH
PSR-006	Absence of BCDR Plan	CRITICAL
PSR-007	Web Application Security Vulnerabilities	CRITICAL
PSR-008	ISMS Credibility Gap – No ISO 27001 Certification	HIGH

7. Detailed Risk Register

PSR-001 — Excessive Privileged Production Access

Risk Category

Access Management / Insider Risk

Affected Asset

Production databases, sensitive customer information and production systems.

Threat

Unauthorised or inappropriate use of privileged access resulting in data exposure, unauthorised changes or operational disruption.

Vulnerability

Three developers retain production database access for convenience, while formal access reviews have not been completed for eight months.

This creates a significant access governance gap because privileged access can accumulate without appropriate validation of business need.

Inherent Risk

CRITICAL

The risk is considered critical due to the combination of:

- Sensitive production data
- Privileged database access
- Lack of timely access reviews

- Potential for intentional or accidental misuse

Risk Velocity

HIGH

Improper use or compromise of privileged access can result in immediate changes, data exposure or disruption.

Risk Interdependencies

This risk contributes to:

- External data breach risk
- Regulatory compliance risk
- Operational disruption
- Insider-related security incidents

Key Risk Indicators

- Number of privileged accounts
- Number of users with production database access
- Overdue access reviews
- Number of privileged access exceptions
- Unnecessary or inactive privileged accounts

Recommended Treatment

MITIGATE

Priority actions:

1. Remove unnecessary production database access.
2. Apply the principle of least privilege.
3. Establish periodic access reviews.
4. Implement formal privileged access governance.
5. Require documented business justification for privileged production access.

Risk Owner

Head of Engineering / IT Leadership

Review Frequency

Monthly until the access governance process is stabilised.

PSR-002 — Critical Vendor Concentration Risk

Risk Category

Third-Party / Operational Resilience Risk

Affected Asset

Critical payment, infrastructure and communications processes.

Threat

A failure, outage or material security incident affecting a highly concentrated vendor could disrupt a significant portion of PaySphere's critical operations.

Vulnerability

AWS, Razorpay and Twilio are used across more than 80% of critical processes.

Additionally, PaySphere does not have a formal vendor risk assessment process.

Inherent Risk

CRITICAL

The risk is critical because multiple business-critical functions depend on a limited number of external providers.

A material failure at one provider could have cascading operational consequences.

Risk Velocity

HIGH

A major vendor outage could immediately affect payment processing, technology availability or customer communication.

Risk Interdependencies

This risk is interconnected with:

- Business continuity risk
- Technology availability
- Customer trust
- Revenue continuity
- Regulatory obligations

Key Risk Indicators

- Critical vendor availability
- Percentage of critical processes dependent on individual vendors
- Vendor outage frequency
- Vendor incidents
- Completion status of vendor risk assessments
- Number of unresolved critical vendor issues

Recommended Treatment

MITIGATE

Priority actions:

1. Establish a formal vendor risk management programme.
2. Identify and document critical vendor dependencies.
3. Perform risk assessments for critical vendors.
4. Evaluate contingency and alternative service options.
5. Define vendor resilience and availability requirements.

Risk Owner

Operations and Technology Leadership, with GRC oversight.

Review Frequency

Quarterly and following material changes to critical vendor relationships.

PSR-A — Regulatory Non-Compliance Risk

Risk Category

Regulatory / Compliance Risk

Affected Asset

PaySphere's regulatory standing, ability to operate and customer trust.

Threat

Regulatory scrutiny, enforcement or adverse consequences resulting from failure to meet applicable data protection and payment-sector obligations.

Vulnerability

Control and governance gaps exist across areas including:

- Access management
- Security awareness
- Incident preparedness
- Risk management
- Information security governance

Inherent Risk

CRITICAL

PaySphere processes highly sensitive personal and financial information while operating in a regulated environment.

Failure to maintain an appropriate control environment could result in significant regulatory and reputational consequences.

Risk Velocity

MEDIUM

Compliance exposure may accumulate over time but can accelerate significantly following:

- A security incident
- A regulatory inquiry
- A customer complaint
- Identification of significant control failures

Risk Interdependencies

This risk is closely connected to:

- Data breach risk
- Access management risk
- Governance weaknesses
- Third-party risk

Key Risk Indicators

- Number of identified compliance gaps
- Overdue compliance remediation actions
- Regulatory findings
- Control assessment results
- Policy review completion rates

Recommended Treatment

MITIGATE

Priority actions:

1. Develop a structured compliance mapping programme.
2. Map regulatory requirements to relevant controls.
3. Assign accountable control owners.
4. Conduct periodic gap assessments.
5. Track remediation through a formal governance process.

Risk Owner

Compliance / GRC Leadership

Review Frequency

Quarterly

PSR-B — External Data Breach Risk

Risk Category

Cybersecurity / Information Security Risk

Affected Asset

Customer:

- KYC information
- Transaction histories
- Bank account details
- Personal information

Threat

An external attacker gains unauthorised access to PaySphere systems and compromises sensitive customer or business information.

Vulnerability

Multiple control uncertainties and security weaknesses across technology and access layers may increase the likelihood of a successful compromise.

Inherent Risk

CRITICAL

A successful data breach could result in:

- Exposure of sensitive information
- Regulatory consequences
- Financial impact
- Customer distrust
- Reputational damage

Risk Velocity

HIGH

Once an attacker gains access, large volumes of data may potentially be accessed or extracted rapidly.

Risk Interdependencies

This is a broad enterprise risk that may materialise through several contributing risks, including:

- Web application vulnerabilities
- Privileged access weaknesses
- Third-party security failures
- Endpoint compromise

Key Risk Indicators

- Security incidents
- Number of critical vulnerabilities
- Suspicious authentication events
- Unresolved high-severity findings
- Security monitoring alerts

Recommended Treatment

MITIGATE

Priority actions:

1. Strengthen preventive and detective security controls.
2. Conduct regular security assessments.
3. Improve vulnerability management.
4. Strengthen monitoring and logging.
5. Establish effective incident response capability.

Risk Owner

Technology / Security Leadership

Review Frequency

Monthly

PSR-005 — Physical Loss of Employee Devices

Risk Category

Physical Security / Endpoint Risk

Affected Asset

Corporate devices and information accessible through employee endpoints.

Threat

Loss or theft of employee devices could lead to unauthorised access to corporate information or systems.

Vulnerability

Endpoint exposure combined with potential weaknesses in:

- Device encryption
- Authentication
- Device management
- Remote revocation capabilities

Inherent Risk

HIGH

The impact of a lost device depends significantly on the security controls applied to the endpoint and the information or systems accessible through it.

Risk Velocity

MEDIUM

The risk may become more severe if a lost device is not quickly detected, disabled or remotely managed.

Risk Interdependencies

This risk can contribute to:

- Unauthorised access
- Information exposure
- External data breach scenarios

Key Risk Indicators

- Number of lost device incidents
- Percentage of devices with encryption enabled
- Endpoint management coverage
- Delays in device revocation
- Devices operating without current security controls

Recommended Treatment

MITIGATE

Priority actions:

1. Implement full-disk encryption.
2. Maintain endpoint management coverage.
3. Enforce strong authentication.
4. Establish remote lock and wipe capabilities.
5. Define procedures for rapid reporting and response to lost devices.

Risk Owner

IT / Endpoint Management

Review Frequency

Quarterly

PSR-006 — Absence of Business Continuity and Disaster Recovery Plan

Risk Category

Business Continuity / Operational Resilience Risk

Affected Asset

Availability and resilience of critical payment and business operations.

Threat

A major operational disruption occurs and PaySphere is unable to recover critical services within acceptable timeframes.

Vulnerability

The organisation does not have a documented Business Continuity and Disaster Recovery plan.

Inherent Risk

CRITICAL

PaySphere's business operations depend on the continuous availability of interconnected technology systems and third-party providers.

A significant disruption without documented recovery arrangements could have an immediate impact on:

- Transactions
- Customers
- Revenue
- Business operations
- Organisational reputation

Risk Velocity

HIGH

A major disruption can immediately affect critical services.

Risk Interdependencies

This risk is strongly connected to:

- Vendor concentration
- Technology outages
- Payment availability
- Operational resilience

Key Risk Indicators

- BCDR test completion
- Recovery test results
- Recovery time performance
- Number of unresolved continuity gaps
- Frequency of continuity plan reviews

Recommended Treatment

MITIGATE

Priority actions:

1. Develop and formally approve BCDR plans.
2. Identify critical business services.
3. Define recovery objectives.
4. Establish recovery procedures.
5. Conduct regular BCDR testing.
6. Track and remediate identified recovery gaps.

Risk Owner

Technology and Operations Leadership

Review Frequency

Quarterly and following significant business or technology changes.

PSR-007 — Web Application Security Vulnerabilities

Merchant Portal

Risk Category

Application Security Risk

Affected Asset

The merchant web portal and backend database connection exposing:

- Customer transaction data
- KYC records
- Merchant account information

Threat

An attacker exploits web application vulnerabilities such as:

- SQL Injection
- Cross-Site Scripting
- Broken authentication

to gain unauthorised access to backend data or compromise merchant accounts.

Vulnerabilities

The identified control uncertainties include:

A. Input and Output Validation

No confirmed input or output sanitisation controls and no confirmed evidence that OWASP-aligned secure coding practices are consistently followed.

B. Authentication and Authorisation

No confirmed MFA for merchant accounts and unclear authentication, session management and access control implementation.

C. Network-Layer Protection

No confirmed Web Application Firewall protecting the merchant web application.

Inherent Risk Scoring

Likelihood: 3/5

The merchant portal is restricted to merchant access rather than being entirely public-facing, which reduces exposure compared with a consumer-facing application.

However, merchants still represent a targetable user base and web application attacks remain a significant threat vector.

Impact: 5/5

Successful exploitation could expose sensitive customer KYC and transaction information and compromise merchant accounts.

Inherent Risk

CRITICAL – 15/25

Risk Velocity

HIGH

Successful exploitation of a web application vulnerability could allow large volumes of information to be accessed or extracted rapidly.

Risk Interdependencies

PSR-007 is a specific pathway through which the broader external data breach risk may materialise.

It is therefore interconnected with:

- PSR-B — External Data Breach Risk
- Regulatory compliance exposure
- Reputational risk
- Merchant relationship and trust risk

Key Risk Indicators

- Results of the latest VAPT
- Number of unpatched or outdated application dependencies
- Failed login attempts
- Security alerts associated with the merchant portal
- WAF or firewall alert volume

Recommended Treatment

MITIGATE

Priority actions:

1. Conduct a Vulnerability Assessment and Penetration Test on the merchant portal.
2. Implement input and output validation aligned with secure coding practices.
3. Enforce MFA for merchant portal accounts.
4. Deploy a Web Application Firewall.
5. Integrate secure code review into the Software Development Lifecycle.

Risk Owner

Head of Engineering / Application Security Lead

GRC Role

The GRC function would:

- Commission and track security testing
- Monitor remediation activities
- Track outstanding findings
- Validate remediation evidence
- Ensure secure SDLC practices are documented

Review Frequency

30 days

PSR-008 — Loss of Enterprise Business Due to ISMS Credibility Gap

No ISO 27001 Certification

Risk Category

Commercial / Reputational / Assurance Risk

Affected Asset

Enterprise and merchant client relationships and revenue generated through B2B contracts requiring vendor security assurance.

Threat

Prospective or existing enterprise clients reject, delay or terminate vendor relationships with PaySphere during security due diligence or TPRM assessments because the organisation cannot demonstrate independent validation of its ISMS.

Vulnerability

PaySphere does not currently hold ISO 27001 certification.

While certification is planned, the organisation does not currently have independent third-party validation of its security posture to present during client procurement and vendor risk assessments.

Inherent Risk Scoring

Likelihood: 4/5

Enterprise procurement processes increasingly evaluate information security assurance when assessing payment and technology vendors.

The absence of recognised independent assurance may create friction as PaySphere attempts to establish relationships with larger enterprise customers.

Impact: 4/5

Lost or delayed enterprise contracts could directly affect:

- Revenue
- Growth opportunities
- Sales cycles
- Business reputation

The impact is significant but primarily commercial and reputational rather than directly equivalent to the impact of a major data breach.

Inherent Risk

HIGH – 16/25

Risk Velocity

LOW

Unlike a data breach or system outage, this risk generally materialises gradually through:

- Lost opportunities
- Extended procurement cycles
- Security due diligence failures
- Enterprise client hesitation

Risk Interdependencies

The credibility gap can become significantly more damaging if other risks materialise.

For example, a major security incident could further reduce enterprise confidence in an organisation that does not already have mature and independently validated information security governance.

Key Risk Indicators

- Number of enterprise deals lost due to security assurance gaps
- Number of deals delayed during security due diligence
- ISO 27001 project progress
- Client security questionnaire outcomes
- Competitor certification status

Recommended Treatment

MITIGATE

Priority actions:

1. Establish a formal ISO 27001 certification timeline.
2. Conduct an ISO 27001 gap assessment.
3. Identify control and documentation gaps.
4. Develop interim security assurance materials for prospective clients.
5. Progress toward certification readiness through a structured implementation programme.

Risk Owner

CEO and CISO jointly

GRC Role

The GRC function would support:

- ISO 27001 gap assessments
- Certification readiness
- Control documentation
- Remediation tracking
- Coordination between security and business stakeholders
- Development of interim assurance materials

Review Frequency

Quarterly until certification is achieved.

8. Key Risk Themes Identified

The assessment identified several broader themes across the eight risks.

8.1 Access Governance

Privileged access management represents a significant area of concern.

The combination of:

- Production database access
- Access retained for convenience
- Delayed access reviews

creates elevated risk to sensitive systems and information.

8.2 Third-Party Dependency

PaySphere's dependence on a small number of critical vendors creates concentration risk.

Vendor risk management is therefore important not only from a security perspective but also from an operational resilience perspective.

8.3 Data Protection Exposure

The organisation handles significant volumes of sensitive personal and financial information.

As a result, technical vulnerabilities, access management weaknesses and third-party failures can have amplified regulatory and reputational consequences.

8.4 Business Resilience

The absence of documented BCDR planning represents a major operational resilience gap.

A technology or vendor disruption could affect the organisation's ability to continue critical payment operations.

8.5 Application Security

The merchant portal represents a specific technical attack pathway capable of contributing to the broader external data breach risk.

This demonstrates the importance of distinguishing between:

- A broad enterprise risk
 - A specific contributing risk or attack pathway
-

8.6 Security Assurance as a Business Risk

The ISO 27001 credibility gap demonstrates that information security risk is not limited to technical incidents.

Security maturity and independent assurance can also influence:

- Enterprise procurement
 - Client trust
 - Revenue opportunities
 - Competitive positioning
-

9. Risk Treatment Strategy

The recommended treatment approach across the register is primarily **risk mitigation**.

Priority should be given to risks capable of causing immediate customer, regulatory or operational impact.

Immediate Priorities

Privileged Access

- Remove unnecessary production access.
- Complete overdue access reviews.
- Establish privileged access governance.

Web Application Security

- Conduct VAPT.
- Identify and remediate high-risk vulnerabilities.
- Strengthen authentication and application protection.

Business Continuity

- Develop BCDR plans.
 - Define recovery objectives.
 - Test critical recovery scenarios.
-

Near-Term Priorities

Vendor Risk Management

- Establish formal vendor assessment processes.
- Identify critical dependencies.
- Monitor concentration risk.

Regulatory Governance

- Map regulatory requirements to organisational controls.
 - Identify compliance gaps.
 - Establish remediation tracking.
-

Strategic Priorities

ISO 27001 Readiness

- Conduct a structured gap assessment.
- Develop an ISMS maturity roadmap.

- Improve control documentation and governance.
 - Progress toward certification readiness.
-

10. GRC Competencies Demonstrated

This project demonstrates practical competencies relevant to a GRC Analyst role.

Risk Identification

Identifying risks based on organisational context rather than relying solely on generic risk categories.

Asset, Threat and Vulnerability Analysis

Separating the affected asset, threat event and underlying vulnerability to create more precise risk statements.

Risk Assessment

Evaluating likelihood and impact to prioritise inherent risk exposure.

Control Gap Analysis

Identifying weaknesses in governance, technology, access management and operational resilience.

Risk Treatment

Developing actionable mitigation strategies and remediation priorities.

Risk Monitoring

Defining KRIs and review timelines to support ongoing governance.

Risk Interdependency Analysis

Recognising how individual risks can contribute to or amplify broader enterprise risks.

Third-Party Risk Management

Assessing vendor dependency and concentration as part of operational resilience.

ISO 27001 Readiness

Recognising the role of information security assurance in governance maturity and enterprise vendor due diligence.

11. Key Learning Outcomes

A major outcome of this project was developing the ability to distinguish between related but fundamentally different risk concepts.

For example:

- A data breach is a broad enterprise risk.
- A web application vulnerability may represent a specific pathway through which that breach occurs.

Similarly:

- Regulatory risk is different from technical security risk.
- A lack of ISO 27001 certification does not automatically mean an organisation is non-compliant or insecure.
- However, the absence of independent assurance can create a commercial and credibility risk during enterprise vendor assessments.

The project also reinforced the importance of separating:

- Threats
- Vulnerabilities
- Risk events
- Control gaps
- Business consequences

This distinction is essential when building actionable risk registers.

12. Project Conclusion

The PaySphere Enterprise Risk Assessment resulted in the development of a structured eight-risk enterprise risk register covering significant exposures across cybersecurity, governance, regulatory compliance, third-party dependency, operational resilience and business assurance.

The project demonstrates an end-to-end GRC risk assessment process involving:

- Understanding organisational context
- Identifying risk scenarios
- Analysing assets, threats and vulnerabilities
- Assessing inherent risk
- Prioritising risk exposure
- Evaluating risk velocity
- Identifying risk interdependencies

- Developing Key Risk Indicators
- Recommending risk treatment
- Assigning risk ownership
- Establishing review timelines

The final risk register provides a baseline that could support future GRC activities such as:

- Control assessments
 - Risk treatment tracking
 - Vendor risk assessments
 - Regulatory compliance mapping
 - Security governance reviews
 - Business continuity planning
 - ISO 27001 readiness activities
-

Portfolio Project Summary

Project Title:

PaySphere Enterprise Risk Assessment and Risk Register Development

Domain:

Governance, Risk and Compliance (GRC)

Project Type:

Simulated Fintech Enterprise Risk Assessment

Primary Deliverable:

Eight-risk enterprise risk register

Risk Areas Covered:

- Access Management
- Cybersecurity
- Data Protection
- Regulatory Compliance
- Third-Party Risk
- Vendor Concentration
- Business Continuity
- Disaster Recovery
- Application Security
- Physical Security
- Information Security Assurance
- ISO 27001 Readiness

Skills Demonstrated:

- Enterprise Risk Assessment

- Risk Register Development
 - Asset, Threat and Vulnerability Analysis
 - Inherent Risk Assessment
 - Cybersecurity Risk Analysis
 - Regulatory Risk Analysis
 - Third-Party Risk Management
 - Control Gap Identification
 - Risk Treatment Planning
 - Key Risk Indicator Development
 - Risk Ownership and Governance
 - Risk Interdependency Analysis
 - ISO 27001 Gap Assessment Concepts
-

Week 1 Outcome:

Successfully developed a portfolio-ready enterprise risk register for a simulated fintech organisation, identifying and prioritising eight critical and high-impact risks and defining structured treatment, ownership and monitoring approaches for each.